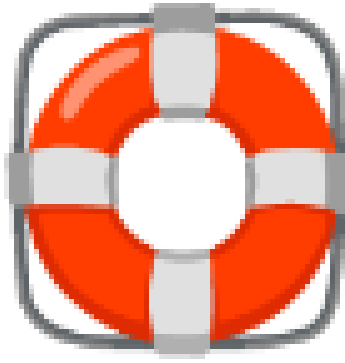


Incident Response Plan



INCIDENT RESPONSE PLAN

An **Incident Response Plan (IRP)** provides a structured approach for detecting, responding to, and recovering from cybersecurity incidents. Below is a detailed IRP tailored for a cybersecurity team associated with Capybara Unlimited, a medium-sized organization.

By integrating this detailed IRP, cybersecurity teams can ensure they are prepared to handle incidents efficiently and minimize their impact on the organization.

I. Objectives



I Objectives

I.1 Minimize Impact:

Reduce damage to systems, data, operations, and business continuity through rapid detection, containment, and response.

I.2 Restore Operations:

Promptly and securely resume critical business functions and IT systems using validated backups and system hardening.

I.3 Enhance Security Posture:

Identify and remediate vulnerabilities exploited during the incident. Implement technical and procedural improvements to strengthen defenses.

I.4 Meet Regulatory Requirements:

Ensure timely compliance with legal, industry, and organizational policies and frameworks (e.g., GDPR, CCPA, HIPAA).



II. Scope



II Scope

This IRP applies to all IT assets, including systems, networks, applications, data, and personnel. It includes internal teams, contractors, third-party vendors, and cloud-based infrastructure relevant to Capybara Unlimited's business operations.



III. Roles & Responsibilities



III Roles & Responsibilities

The IR team consists of:

III.1 Incident Command

Oversees and coordinates the incident response effort, making critical decisions, managing communication, and ensuring alignment with business goals.

III.2 SOC Analysts

Detect, investigate, and analyze threats using SIEM, EDR, IDS/IPS, and threat intelligence platforms.

III.3 Forensic Specialists

Conduct in-depth investigation of compromised systems, collect digital evidence, and support legal/compliance outcomes.

III.4 IT Administrators

Implement response measures including system isolation, patching, account management, and system recovery.

III.5 Legal and Compliance Team

Evaluate legal risk and regulatory exposure. Guide notification timelines and documentation required under laws such as GDPR, HIPAA, and CCPA.

III.6 Communications/Public Relations:

Coordinate internal and external communications, ensuring consistent and accurate messaging to stakeholders, media, and customers.

III.7 HR and People Operations (if relevant)

Support employee communications during incidents (e.g., phishing, insider threats). Assist with internal investigations where appropriate.

IV. Incident Response Lifecycle



IV Incident Response Lifecycle

Follow the **NIST Cybersecurity Framework's Incident Response Process**:

IV.1 Preparation

- [IV.1.1 Develop policies](#)
- [IV.1.2 Train personnel](#)
- [IV.1.3 Implement tools](#)
- [IV.1.4 Create playbooks](#)

IV.2 Detection and Analysis

IV.2.1 Identify incidents

- [IV.2.1.a SIEM](#)
- [IV.2.1.b EDR](#)
- [IV.2.1.c Network logs](#)

IV.2.2 Classify incidents

- [IV.2.2.a Severity levels](#)
- [IV.2.2.b Type](#)

IV.2.3 Collect evidence

- [IV.2.3.a Logs](#)
- [IV.2.3.b Malware](#)
- [IV.2.3.c Email headers](#)

IV.2.4 Decision points

- [IV.2.4.a Escalate to leadership](#)
- [IV.2.4.b Scope-based containment](#)

IV.3 Containment

IV.3.1 Immediate steps

- [IV.3.1.a Affected systems](#)
- [IV.3.1.b Affected accounts](#)
- [IV.3.1.c Firewall rules](#)

[IV.3.2 Short-term actions](#)

[IV.3.2.a Disable infected devices](#)

[IV.3.2.b Redirect to alternative systems](#)

[IV.3.3 Long-term actions](#)

[IV.3.3.a Patch management](#)

[IV.3.3.b Network segmentation](#)

[IV.4 Eradication](#)

[IV.4.1 Remove malware](#)

[IV.4.1.a Remove infection \(automated\)](#)

[IV.4.1.b Remove infection \(manual\)](#)

[IV.4.2 Address root cause](#)

[IV.4.2.a Root cause analysis](#)

[IV.4.1.b Remove persistence mechanisms](#)

[IV.5 Recovery](#)

[IV.5.1 Restore operations](#)

[IV.5.1.a Restore from backup](#)

[IV.5.1.b Validate backup integrity](#)

[IV.5.2 Monitor post-incident](#)

[IV.5.2.a Watch for re-infection](#)

[IV.5.2.b Reduce visibility gaps](#)

[IV.6 Post-Incident Analysis](#)

[IV.6.1 Conduct review](#)

[IV.6.1.a Create timeline](#)

[IV.6.1.b Evaluate processes](#)

[IV.6.2 Document findings](#)

[IV.6.2.a Incident report](#)

[IV.6.2.b Lessons learned](#)

[IV.6.3 Implement changes](#)

[IV.6.3.a Update IR processes](#)

[IV.6.3.b Implement mitigations](#)

IV.1 Preparation

IV.1.1 Develop policies

Define incident categories, thresholds, roles, escalation paths, and acceptable response times.

IV.1.2 Train personnel

Run frequent training and tabletop simulations for all relevant teams.

IV.1.3 Implement tools

Maintain updated and integrated security tools, including SIEM, EDR, backup systems, forensic platforms, and secure communications.

IV.1.4 Create playbooks

Create scenario-specific guides for phishing, malware, DDoS, insider threats, and data breaches.

IV.2 Detection and Analysis

IV.2.1 Identify incidents

Monitor systems for suspicious activity using:

IV.2.1.a SIEM

Monitor alerts, correlate logs, and detect anomalies.

IV.2.1.b EDR

Spot malware behavior, persistence, or unusual file/process activity.

IV.2.1.c Network logs

Detect lateral movement, data exfiltration, and anomalous traffic patterns.

IV.2.2 Classify incidents

Classify incidents in terms of **severity** and **type**.

IV.2.2.a Severity levels

- Low
- Medium
- High
- Critical (based on scope, impact, and exploitability)

IV.2.2.b Type

- Malware
- Phishing
- Insider threat
- DoS/DDoS
- Data Breach

IV.2.3 Collect evidence

IV.2.3.a Logs

Logs (system, application, network).

IV.2.3.b Malware

Malware samples.

IV.2.3.c Email headers

Email headers for phishing attempts.

IV.2.4 Decision points

IV.2.4.a Escalate to leadership

Escalate to leadership when business risk exceeds internal thresholds.

IV.2.4.b Scope-based containment

Determine containment steps based on scope and impact.

IV.3 Containment

IV.3.1 Immediate steps

IV.3.1.a Affected systems

Disconnect infected devices immediately.

IV.3.1.b Affected accounts

Disable credentials or enforce MFA reset.

IV.3.1.c Firewall rules

Block malicious IPs and restrict lateral movement.

IV.3.2 Short-term actions

IV.3.2.a Disable infected devices

Disable infected devices but preserve forensic evidence.

IV.3.2.b Redirect to alternative systems

Redirect traffic to backup or alternate services.

IV.3.3 Long-term actions

IV.3.3.a Patch management

Apply vendor patches.

IV.3.3.b Network segmentation

Segment network to contain potential future threats.

IV.4 Eradication

IV.4.1 Remove malware

IV.4.1.a Remove infection (automated)

Use automated EDR tools.

IV.4.1.b Remove infection (manual)

Escalate to manual if required for persistent threats.

IV.4.2 Address root cause

IV.4.2.a Root cause analysis

Identify attack vector (e.g., phishing, outdated software).

IV.4.1.b Remove persistence mechanisms

Delete registry keys, malicious tasks, backdoors.

IV.5 Recovery

IV.5.1 Restore operations

IV.5.1.a Restore from backup

Rebuild affected systems from known-good backups.(Use verified clean backups.)

IV.5.1.b Validate backup integrity

Validate system integrity and ensure no residual threats exist.

IV.5.2 Monitor post-incident

IV.5.2.a Watch for re-infection

Closely watch affected systems for signs of re-infection.

IV.5.2.b Reduce visibility gaps

Improve visibility with updated SIEM rules and indicators of compromise (IOCs).

IV.6 Post-Incident Analysis

IV.6.1 Conduct review

IV.6.1.a Create timeline

Create a timeline of the incident.

IV.6.1.b Evaluate processes

Evaluate the effectiveness of detection, containment, eradication, and recovery.

IV.6.2 Document findings

IV.6.2.a Incident report

Write a comprehensive incident report.

IV.6.2.b Lessons learned

Summarize lessons learned and proposed improvements.

IV.6.3 Implement changes

IV.6.3.a Update IR processes

Update the IRP and playbooks.

IV.6.3.b Implement mitigations

Strengthen defenses based on vulnerabilities identified during the attack.

V. Communication Plan



V Communication Plan

V.1 Internal Communication

V.1.a

Notify leadership and affected departments immediately.

V.1.b

Provide regular updates during incident response.

V.2 External Communication

V.2.a

Inform customers or partners if required.

V.2.b

Evaluate the potential regulatory and financial impact of reporting incidents. In cases where disclosure could result in significant penalties, carefully assess whether the incident qualifies for mandatory reporting under current regulations, and consider limiting external communication accordingly.

V.2.c

Public statements must be cleared by Legal and PR; never withhold required disclosures due to fear of reputational impact.

VI Key Performance Indicators (KPIs)



VI Key Performance Indicators (KPIs)

VI.1 Time to Detect (TTD)

Measure time from incident onset to detection.

VI.2 Time to Contain (TTC)

Measure speed of isolating affected systems

VI.3 Time to Recover Baseline Security Posture (TTR)

Measure the time taken to restore security measures

VI.4 Incident Closure Rate

Percentage of incidents successfully resolved within defined timeframes.

VI.5 Post-Incident Improvement Rate

Number or percentage of lessons learned that resulted in implemented improvements.



VII. Common Mistakes & Mitigations



VII Common Mistakes & Mitigations

VII.1 Overlooking early indicators

VII.1.a Mistake

Dismissing minor anomalies as false positives.

VII.1.b Mitigation

Tune SIEM to flag recurring low-level anomalies.

VII.2 Inadequate documentation

VII.2.a Mistake

Failing to log actions during incident response.

VII.2.b Mitigation

Assign documentation scribe at incident start.

VII.3 Premature recovery

VII.3.a Mistake

Reconnecting systems before complete eradication.

VII.3.b Mitigation

Perform thorough validation before resuming operations(Use verified checklist and peer review.).

VII.4 Neglecting post-incident reviews

VII.3.a Mistake

Skipping post-mortem analysis due to time constraints (Not conducting reviews.).

VII.3.b Mitigation

Make reviews mandatory for incident closure.

VIII. Tools & Techniques



VIII Tools & Techniques

VIII.1 Detection

SIEM (Splunk, QRadar), IDS/IPS (Snort, Suricata), EDR (CrowdStrike, SentinelOne).

VIII.2 Containment

NAC (Cisco ISE), firewalls (Palo Alto, Fortinet).

VIII.3 Eradication

Antivirus/Antimalware (Sophos, Malwarebytes, Windows Defender, SentinelOne).

VIII.4 Recovery

Backup solutions (Veeam, Acronis).

VIII.5 Analysis

Forensic tools (FTK, EnCase, Wireshark).



IX. Review & Maintenance



IX Review and Maintenance

IX.1 Annual updates

Conduct formal annual review of the IRP for regulatory and threat landscape alignment.

IX.2 Ongoing Training

Conduct quarterly IR exercises, simulations, and phishing tests.

IX.3 First-Party Audits

Use external red teams or auditors to assess IR plan effectiveness and uncover blind spots.

Appendix



APPENDIX





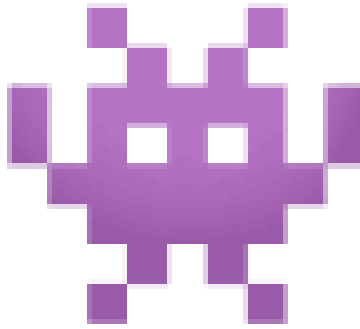
Playbooks



IR PLAYBOOKS



Malware Infection



Malware Infection Playbook

1. Identify and contain the malware

Quickly detect and limit the spread of the malware to minimize damage.

1.1 Identify and observe infected systems

Allow infected systems to remain online to avoid disrupting business operations and gather further data on the malware.

1.2 Conduct preliminary analysis

Gather initial indicators of compromise (e.g., suspicious files, processes, or connections) to inform containment strategies.

2. Perform static analysis of the malware sample

Analyze the malware file without executing it to understand its characteristics.

2.1 Inspect file structure and metadata

Examine the malware file's properties, including size, hash values, and embedded metadata.

2.2 Extract embedded strings and suspicious code

Use tools like VirusTotal to identify readable text and suspicious code within the file.

3. Perform dynamic analysis in a controlled environment

Observe malware behavior in real-time to understand its operational capabilities.

3.1 Execute malware on a clean system

NEVER use production systems. Instead, deploy to a malware sandbox or virtual environment for behavioral observation.

3.2 Record system modifications and activities

Document changes to the registry, file systems, and active processes during execution.

4. Conduct network traffic analysis

Analyze communication attempts made by the malware to uncover external connections.

4.1 Capture network traffic

Use packet-capturing tools to monitor network activity generated by the malware.

4.2 Identify external entities

Look for connections to command-and-control (C2) servers or data exfiltration endpoints.

5. Investigate behavioral patterns and persistence mechanisms

Determine how the malware survives and operates over time.

5.1 Identify persistence techniques

Investigate changes such as registry modifications, scheduled tasks, or startup files.

5.2 Examine behavioral indicators

Look for recurring patterns, such as periodic network requests or file executions.

6. Eradicate the malware and recover systems

Remove the malware and restore affected systems to their original state.

6.1 Deploy cleanup tools

Use antivirus or specialized malware removal tools to eradicate infections.

6.2 Restore from clean backups

Reinstall systems and data using backups confirmed to be malware-free.

6.3 Apply mitigations to prevent reinfection

Address any vulnerabilities that permitted the original infection to occur by applying the appropriate mitigation.

7. Post-incident reporting and prevention

Document lessons learned and strengthen defenses against future incidents.

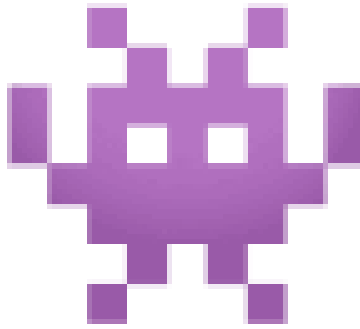
7.1 Generate incident report

Detail findings, response steps, and impact assessment in a comprehensive report.

7.2 Implement prevention measures

Update security policies, patch vulnerabilities, and educate staff to avoid recurrence.

Phishing



Phishing Playbook

1. Identify and verify the phishing email

Confirm that the suspicious email is a phishing attempt, not a legitimate message.

1.1 Analyze email headers and content

Inspect email headers for inconsistencies like mismatched sender domains or unusual reply-to addresses. Review the content for generic greetings, poor grammar, or urgent requests for sensitive information.

1.2 Compare against known phishing indicators

Cross-check email elements against known phishing indicators, such as fake links (hover over to inspect URLs), suspicious attachments, or spoofed branding.

2. Contain the threat

Prevent further exposure or escalation.

2.1 Isolate the email

Instruct recipients not to click any links, open attachments, or reply. Move the email to a quarantined folder or flag it as phishing.

2.2 Notify IT/security team

Report the phishing email to the organization's security team immediately, following internal reporting procedures.

3. Investigate the impact

Determine the extent of the threat and affected users.

3.1 Verify user interaction

Use logs and endpoint monitoring to determine whether any users clicked links, downloaded attachments, or entered credentials. Don't rely solely on self-reporting validate through tooling

3.2 Check affected systems

Use endpoint detection and response (EDR) tools to monitor devices for unusual activity or malware from potential downloads.

4. Eradicate the threat

Retain a copy for analysis in a sandbox environment. Do not delete until full analysis is complete.

4.1 Preserve phishing emails

Leave the phishing emails in user inboxes for the security team to study.

4.2 Secure compromised accounts

If credentials were entered, reset passwords immediately and monitor account activity for unauthorized access.

5. Educate and prevent future incidents

Strengthen user awareness and defenses.

5.1 Notify all employees

Inform staff of the phishing attempt with neutral, clear communication. Share only actionable facts (e.g., "Beware of emails titled 'Payroll Update'") to avoid panic.

5.2 Provide training

Conduct phishing awareness sessions and simulated phishing exercises to reinforce detection skills.

6. Monitor and report

Ensure no residual threats remain and document the incident.

6.1 Monitor for reoccurrence

Track systems and user accounts for unusual activity linked to the phishing attempt.

6.2 Document the incident

Log the phishing attack, actions taken, and lessons learned to refine future response efforts.

Denial-of-Service



Denial-of-Service Playbook

1. Identify and characterize the attack traffic

Confirm the nature of the traffic to ensure it's consistent with a DoS attack rather than a legitimate traffic spike.

1.1 Automate detection of unusual number of packets

Use network monitoring tools to identify unusual traffic patterns, such as excessive requests from specific IPs or a high volume of specific packet types.

1.2 Classify the type of DoS

Characterize the traffic to determine if it aligns with known DoS attack patterns (e.g., SYN flood, ICMP flood).

2. Measure traffic volume and bandwidth consumption

Accurately assess traffic volume to prioritize resources and decide on appropriate mitigation strategies.

2.1 Assess scope of DoS

Monitor network metrics to assess the scope, including packet size, rate of incoming requests, and bandwidth impact.

2.2 Evaluate impact of DoS

Use these metrics to understand the impact on network resources and how severely the attack affects performance.

3. Locate the source of attack traffic

Identify potential malicious sources to inform targeted blocking or rate-limiting actions.

3.1 Identify patterns in DoS traffic source

Use IP tracking and network monitoring to identify patterns in IP addresses, geographic sources, or ASN numbers.

3.2 Analyze identified patterns

Document any consistent IP ranges or indicators that suggest botnet involvement or attack origin.

4. Identify affected services and network components

Pinpoint affected systems to prioritize protective measures and service continuity efforts.

4.1 Identify affected internal systems

Use logs and network monitoring to determine which servers, services, or endpoints are being targeted by the attack (e.g., web servers, DNS).

5. Implement and monitor mitigation measures

Ensure mitigation is effectively reducing malicious traffic while maintaining service availability for legitimate users.

5.1 Implement firewall rules

Apply network defenses such as firewall rules or rate-limiting based on the type of DoS attack.

5.2 Monitor effectiveness of firewall mitigations

Use network monitoring tools to continuously assess the effectiveness of these defenses.